



Ауторизација над ресурсом и класификација података

Одлука о приступу зависи од субјекта, ресурса и контекста

Проблем који решавамо

Ауторизација има смисла тек када је везана за конкретан ресурс и његов контекст. Корисник може имати легитимну улогу, а ипак не сме да чита, мења или дели баш тај запис. Зато се одлука не завршава провером типа ендпоинта или назива улоге.

ПРОБЛЕМ

Шта може поћи по злу

Ауторизација има смисла тек када је везана за конкретан ресурс и његов контекст. Корисник може имати легитимну улогу, а ипак не сме да чита, мења или дели баш тај запис. Зато се одлука не завршава провером типа ендпоинта или назива улоге.

ЗАШТО

Зашто је тема важна

Класификација података даје исти језик власницима, развоју и операцијама. Када систем зна колико је податак осетљив, може да примени одговарајући приступ, приказ, чување и евиденцију без ослањања на нечије сећање.

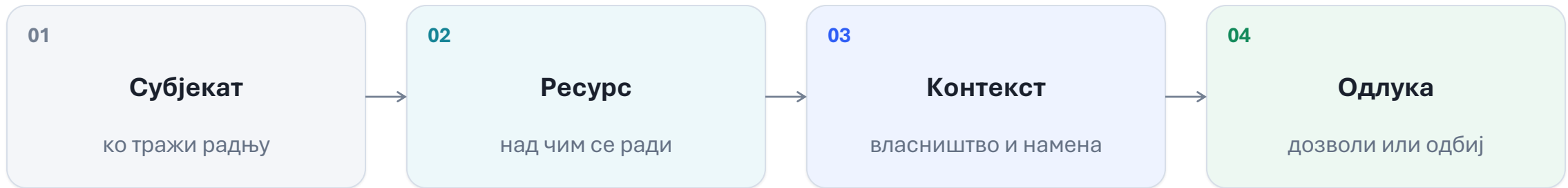
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Идентификатор у адреси не представља право приступа. Однос субјекта према ресурсу проверава се на серверу.

Субјекат

ко тражи радњу

01

Провера права укључује субјект, радњу, ресурс и његову припадност.

Питање: који улаз покреће ову одлуку?

02

Одлука укључује идентитет, тражену радњу, ресурс и припадност ресурса одговарајућем домену или власнику.

Питање: која граница мора бити видљива?

03

Класификација има пословно значење које сви чланови тима тумаче на исти начин.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

Ресурс

над чим се ради

01

Одбијање не треба да открива садржај нити постојање туђег осетљивог ресурса.

Питање: који улаз покреће ову одлуку?

02

Исти принцип важи за API позив, извоз података и позадинску обраду, не само за екран који корисник види.

Питање: која граница мора бити видљива?

03

Правила за приказ и извоз треба да буду строжа када последице грешке расту.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

Контекст

Власништво и намена

01

Класификација није етикета за документацију, већ улаз у правила руковања подацима.

Питање: који улаз покреће ову одлуку?

02

Одговор на одбијени приступ треба да буде користан клијенту, али не сме да открије податке о заштићеном запису.

Питање: која граница мора бити видљива?

03

Власник податка одговара за оправданост промене класификације, а систем чува траг те промене.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

Одлука

дозволи или одбиј

01

Класификација има пословно значење које сви чланови тима тумаче на исти начин.

Питање: који улаз покреће ову одлуку?

02

Правила за приказ и извоз треба да буду строжа када последице грешке расту.

Питање: која граница мора бити видљива?

03

Власник податка одговара за оправданост промене класификације, а систем чува траг те промене.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

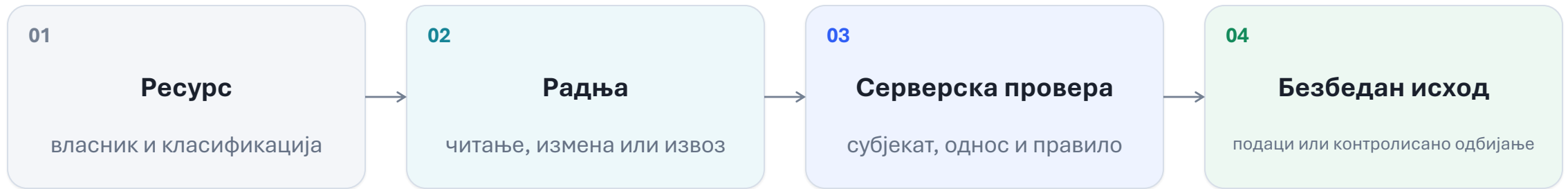
Нивои провере приступа

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Ниво	Шта проверава	Зашто није довољан сам
Пријава	Идентитет субјекта.	Не говори шта субјекат сме да уради.
Улога	Општи скуп одговорности.	Не зна однос према конкретном запису.
Ресурс	Власништво, припадност и класификацију.	Мора се комбиновати са радњом и политиком.
Контекст	Време, стање и пословно оправдање.	Може променити закључак за исту улогу.

Шема заштите једног ресурса

Идентификатор у адреси не представља право приступа. Однос субјекта према ресурсу проверава се на серверу.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Животни циклус податка

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Животни циклус податка

Заштита података не завршава се у тренутку читања. Исти податак пролази кроз креирање, употребу, дељење, чување и уклањање. Свака фаза поставља друго питање о дозвољеном приступу и потребном трагу.

01

При креирању се одређују власник и класификација.

02

При коришћењу се проверава сврха и опсег приступа.

03

При дељењу се проверава граница поверења и минимални скуп података.

04

При чувању и уклањању важе ретентион и audit правила.

Одлука мора имати контекст

Три правила која треба да остану видљива у имплементацији и ревизији.

01

Провера права укључује субјект, радњу, ресурс и његову припадност.

Јасно правило

02

Одбијање не треба да открива садржај нити постојање туђег осетљивог ресурса.

Проверљива примена

03

Класификација није етикета за документацију, већ улаз у правила руковања подацима.

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

За сваку значајну операцију тим формулише и позитиван и негативан сценарио. Негативан сценарио проверава да правилно пријављен корисник не може да заобиђе власништво променом идентификатора или позивом API-ја ван интерфејса.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: исправна улога, погрешан запис

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: исправна улога, погрешан запис

Два члана тима имају исту улогу и обојица могу да прегледају захтеве. Један мења идентификатор у адреси захтева и долази до туђег записа. Систем који проверава само улогу сматра захтев дозвољеним, иако се променио најважнији део контекста: однос корисника према конкретном ресурсу.

01

Одлука укључује идентитет, тражену радњу, ресурс и припадност ресурса одговарајућем домену или власнику.

02

Исти принцип важи за API позив, извоз података и позадинску обраду, не само за екран који корисник види.

03

Одговор на одбијени приступ треба да буде користан клијенту, али не сме да открије податке о заштићеном запису.

Одлука се доноси над конкретним ресурсом

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public Result<RecordDto> Read(UserContext user, Record record)
2 {
3     if (!user.Can("record.read")) return Result.Forbidden();
4     var ownsRecord = record.OwnerId == user.Id;
5     var canReadAll = user.Can("record.read.all");
6     if (!ownsRecord && !canReadAll) return Result.NotFound();
7     if (!policy.Allows(record.Classification, user.Clearance))
8         return Result.Forbidden();
9     return Result.Ok(mapper.ToDto(record));
10 }
```

ШТА ЈЕ ВАЖНО

Иста улога не значи исти приступ сваком запису. Сервер проверава дозволу, власништво и класификацију.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Негативан тест доказује границу

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Fact]
2 public void Reader_cannot_open_another_users_record()
3 {
4     var user = User.With("record.read", id: "u-17");
5     var record = Record.OwnedBy("u-99", Classification.Internal);
6
7     var result = service.Read(user, record);
8
9     result.Status.Should().Be(Status.NotFound);
10    audit.Last.Outcome.Should().Be("denied");
11 }
```

ДОКАЗ

Тест мења само власника ресурса и очекује одбијање без откривања туђих података.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "actor": "u-17",  
3   "action": "record.read",  
4   "target": "record-93",  
5   "classification": "internal",  
6   "outcome": "denied",  
7   "reason": "scope_mismatch"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, токен, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

Провера улоге без провере односа према конкретном ресурсу.

Нема јасног власника одлуке.

02

Филтрирање листе у клијенту без исте провере на серверу.

Не постоји негативан сценарио.

03

Снижавање класификације без образложења и трага промене.

Доказ не показује стварни исход.

Како знамо да је ауторизација потпуна

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Како знамо да је ауторизација потпуна

Приступ треба проверити кроз стварну границу система, а не само кроз кориснички интерфејс. То значи да директан API захтев, позадински процес и извоз не могу прескочити исто правило. Негативни тестови зато нису додатак после имплементације, већ најјаснији опис границе приступа.

01

Систем једнако штити ресурс када се захтев пошаље ван стандардног екрана.

02

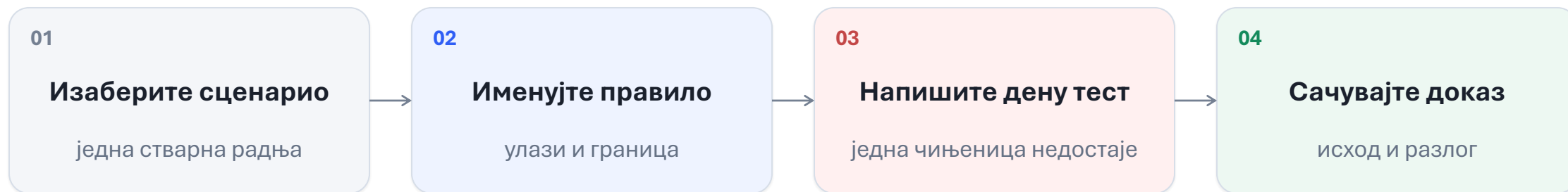
Одбијени захтев не враћа детаље који помажу да се мапирају туђи подаци.

03

Промена класификације и промена власништва остављају довољно трага за каснији преглед.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

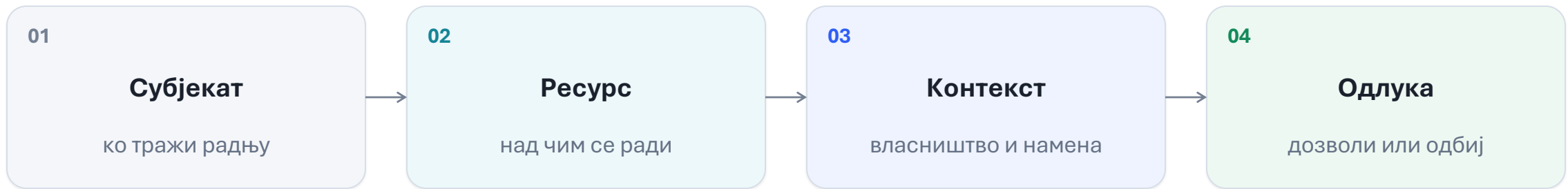


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „Ауторизација над ресурсом и класификација података“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-а.



ЗА ЗАВРШЕТАК

Који ресурс носи ризик хоризонталног приступа и које информације одлука мора да узме у обзир?

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.